

| Event                                                                                                                                                         |  |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------|--|
| 2024-09-20 00:33:18   OS   149.88.25.133:64646 → 172.16.17.129:22   Action Details: Accepted password for analyst from 149.88.25.133 port 64646 ssh2          |  |
| 2024-09-20 00:32:33   OS   149.88.25.133:36864 → 172.16.17.129:22   Action Details: Failed password for letdefend from 149.88.25.133 port 36864 ssh2          |  |
| 2024-09-20 00:32:32   OS   149.88.25.133:21024 → 172.16.17.129:22   Action Details: Failed password for invalid user users from 149.88.25.133 port 21024 ssh2 |  |
| 2024-09-20 00:32:31   OS   149.88.25.133:19540 → 172.16.17.129:22   Action Details: Failed password for invalid user users from 149.88.25.133 port 19540 ssh2 |  |
| 2024-09-20 00:32:30   OS   149.88.25.133:4076 → 172.16.17.129:22   Action Details: Accepted password for letdefend from 149.88.25.133 port 4076 ssh2          |  |
| 2024-09-20 00:32:30   OS   149.88.25.133:8549 → 172.16.17.129:22   Action Details: Failed password for invalid user test from 149.88.25.133 port 8549 ssh2    |  |
| 2024-09-20 00:32:29   OS   149.88.25.133:2701 → 172.16.17.129:22   Action Details: Failed password for invalid user test from 149.88.25.133 port 2701 ssh2    |  |

| 🔍 | Event 3                                                                                                                                               |
|---|-------------------------------------------------------------------------------------------------------------------------------------------------------|
| ▼ | 2024-09-20 00:33:18   OS   149.88.25.133:64646 → 172.16.17.129:22   Action Details: Accepted password for analyst from 149.88.25.133 port 64646 ssh2  |
| ▼ | 2024-09-20 00:32:30   OS   149.88.25.133:4076 → 172.16.17.129:22   Action Details: Accepted password for letsdefend from 149.88.25.133 port 4076 ssh2 |
| ▼ | 2024-09-20 00:32:25   OS   149.88.25.133:55080 → 172.16.17.129:22   Action Details: Accepted password for analyst from 149.88.25.133 port 55080 ssh2  |

AbuseIPDB

[Report IP](#)
[Bulk Checker](#)
[Bulk Reporter](#)
[Pricing](#)
[Integrations](#)
[Docs](#)
[IP Utilities](#)
[Contact](#)
[More](#)

[Login](#)
[Sign Up](#)

NEW

Welcome to the new IP check page! We're rolling it out gradually and would love your input. Spot a bug, or have a suggestion?

SHARE FEEDBACK

149.88.25.133

ACTIVITY TRENDING DOWN

ABUSE CONFIDENCE SCORE
83 reports  
40 reporters - latest 1 week ago

20% Elevated

ISP

Datacamp Limited

Usage Type

Data Center/Web Hosting/Transit

ASN

[AS212238](#)

Hostname(s)

unn-149-88-25-133.datapacket.com

Domain Name

datapack.co.uk

Country

 United States of America

City

Chicago, Illinois

REPORT

WHOIS

ISP, Usage Type, and Location provided by IPinfo. Updated weekly.

Log in to view charts and search reports for this IP.

HIDE CHARTS

LOG IN

Reports Activity

Report Categories

Top Reporter Countries Map

Reports Activity

EXAMPLE PREVIEW

Account required for the enhanced features

Log In Sign up

| EVENT TIME          | COMMAND LINE                |
|---------------------|-----------------------------|
| 2024-09-20 06:36:22 | getent passwd               |
| 2024-09-20 06:36:13 | groups letsdefend1          |
| 2024-09-20 06:36:03 | sudo cat /etc/sudoers       |
| 2024-09-20 06:35:26 | sudo visudo                 |
| 2024-09-20 06:35:12 | sudo cat /etc/sudoers       |
| 2024-09-20 06:34:57 | sudo -l                     |
| 2024-09-20 06:34:32 | sudo passwd letsdefend1     |
| 2024-09-20 06:34:24 | sudo useradd -m letsdefend1 |
| 2024-09-20 06:33:48 | whoami                      |

No EDR é possível identificar uma sequência de comandos, onde ele cria um usuário novo, verifica suas permissões de sudo, altera o arquivo sudoers, provavelmente adicionando o novo usuário, verifica o usuário criado com groups e getent passwd para enumerar as contas cadastradas no sistema.

Checando:

```
root@ip-172-31-47-197:/home# cat analyst/.bash_history
whoami
groups analyst
sudo su
root@ip-172-31-47-197:/home# ls
analyst letsdefend letsdefend1 root ubuntu
root@ip-172-31-47-197:/home# history
history: command not found
root@ip-172-31-47-197:/home# history
 1 2024-09-20 06:33:48 whoami
 2 2024-09-20 06:34:24 sudo useradd -m letsdefend1
 3 2024-09-20 06:34:32 sudo passwd letsdefend1
 4 2024-09-20 06:34:57 sudo -l
 5 2024-09-20 06:35:12 sudo cat /etc/sudoers
 6 2024-09-20 06:35:26 sudo visudo
 7 2024-09-20 06:36:03 sudo cat /etc/sudoers
 8 2024-09-20 06:36:13 groups letsdefend1
 9 2024-09-20 06:36:22 getent passwd
```

Cat /etc/passwd:

```
gnome-initial-setup:x:128:65534:./run/gnome-initial-setup:/bin/false
speech-dispatcher:x:129:29:Speech Dispatcher,,./run/speech-dispatcher:/bin/false
nm-openvpn:x:130:136:NetworkManager OpenVPN,,./var/lib/openvpn/chroot:/usr/sbin/nologin
hplip:x:131:7:HPLIP system user,,./run/hplip:/bin/false
letsdefend1:x:1003:1003:./home/letsdefend1:/bin/sh
```

Verificamos que o usuário foi realmente criado verificando o arquivo /etc/passwd

```
%sudo ALL=(ALL:ALL) ALL

# See sudoers(5) for more information on "#include" directives:

#includedir /etc/sudoers.d
$USER ALL=(ALL) NOPASSWD: ALL
analyst ALL=(ALL) NOPASSWD: ALL
letsdefend1 ALL=(ALL) NOPASSWD: ALL
```

Ele também conseguiu colocar o novo usuário com todas as permissões sudo no arquivo /etc/sudoers

É bom ver o que o outro usuário comprometido “letsdefend” fez também:

```

root@ip-172-31-45-116:~# cat /home/letsdefend/.bash_history
nano .bash_history
exit
ls
crontab -e
nano hello.txt
history
exit
root@ip-172-31-45-116:~#

root@ip-172-31-45-116:/home/letsdefend# crontab -l
# m h dom mon dow   command
@reboot sudo /usr/bin/vncserver :1
@reboot /usr/bin/websockify -D --web=/usr/share/novnc/ 433 localhost:5901
root@ip-172-31-45-116:/home/letsdefend#

```

Aparentemente foi criada uma tarefa agendada para abrir um VNC na porta 5901 sempre que a máquina for iniciada.

**T1110** - BruteForce

**T1033** - System Owner/User Discovery

**T1136** - Create Account

**T1548** - Abuse Elevation Control Mechanism

**T1053** - Scheduled Task/Job

## Horário:

20-09-2024 06:35:26

## IoCs:

### Endereços IP:

149.88.25.133

### Username criado:

Letsdefend1

### Arquivo alterado:

/etc/sudoers

### Comando:

sudo visudo

### Tarefa agendada:

@reboot /usr/bin/websockify -D --web=/usr/share/novnc/ 433 localhost:5901

## Vetor de Ataque:

Ssh exposto a internet, o atacante utilizou bruteforce e obteve sucesso nas contas letsdefend e analyst na máquina de IP 172.16.17.129

## Análise:

O atacante obteve sucesso a duas contas no bruteforce, primeiro ele utilizou comandos para reconhecimento de usuário/grupos com “whoami”, depois criou a conta letsdefend1, verificou suas permissões sudo com “sudo -l”, após a verificação foi possível afirmar que ele deu permissão ALL:ALL para essa conta nos sudoers, alterando o /etc/sudoers com “sudo visudo”, verificando também o histórico da conta letsdefend é possível observar que ele agendou uma tarefa, onde a porta 5901 com serviço VNC é aberta ao iniciar o host, então ele utilizou tanto de criação de usuário quanto agendar um serviço para persistência.

Para evitar detecção ele utilizou a técnica **Abuse Elevation Control Mechanism (T1548)**.

O IP veio de uma rede externa e foi dado como suspeito por fontes como AbuseIPDB.

Aparentemente nenhum outro host/usuário foi comprometido

## Recomendações:

- Desabilitar e resetar as senhas das contas comprometidas
- Isolar a máquina da rede
- Bloquear IP malicioso
- Aplicar uma política de senhas forte
- Não expor serviços de conexão remota como SSH para a internet caso não for necessário